

CYBERSECURITY SOC COPILOT

Multi-Agent Incident Investigation and Response Assistant

Portfolio Technical Report

Author: Naman Saini

Date: 22 September 2026

Python • FastAPI • Streamlit • RAG • MCP • Pydantic • ReportLab

Defensive use only | Synthetic portfolio data

Table of Contents

Section	Page
Executive Summary	3
Introduction	4
Background	5
System Architecture	6
Dataset	7
RAG Implementation	8
MCP Implementation	9
Multi-Agent Architecture	10
Implementation	11
Example Investigation	12
Dashboard	13
Evaluation and Results	14
Safety and Security	15
Limitations, Future Work, Conclusion	16
References	17
Appendix	18

Report scope

This report documents a working, offline-capable MVP and a controlled path to a production-grade system. Claims about accuracy are limited to three synthetic labelled cases; they are not presented as evidence of real-world detection performance.

1. Executive Summary

Security Operations Center analysts must combine noisy alerts, fragmented telemetry, threat context, procedures, and business impact under time pressure. The project implements a defensive SOC Copilot that structures this work while preserving analyst control.

The MVP ingests normalized synthetic alerts, runs auditable triage and investigation functions, retrieves controlled playbooks through a citation-producing RAG baseline, evaluates risk with an explicit formula, proposes defensive actions, and exports incident JSON and PDF reports. A Streamlit dashboard and FastAPI service expose the workflow. Three narrow MCP servers demonstrate least-privilege access to logs, approved intelligence, and draft incidents.

A deterministic baseline was selected before adding a hosted LLM. This ensures the repository runs without credentials, gives evaluation a stable comparator, and prevents polished language from masking unsupported reasoning. Future LLM adapters must return validated schemas and obey the same evidence, authorization, and traceability controls.

2. Introduction

SOC teams face alert fatigue because detection systems can generate more work than analysts can investigate consistently. Manual evidence collection, query switching, timeline construction, playbook lookup, and reporting create delay and variation. The useful opportunity for an LLM is not autonomous security action; it is controlled synthesis around verifiable evidence.

The project objectives are to shorten investigation preparation, preserve provenance, retrieve relevant procedures, calculate explainable risk, map observed behavior to ATT&CK; only when supported, and produce reviewable incident records. The system is explicitly defensive and uses public, synthetic, lab-generated, or authorized data.

Success is measured through classification, retrieval, citation, grounding, escalation, mapping, tool selection, consistency, and recovery metrics. Fluent prose alone is not a success criterion.

3. Background

Incident response typically moves through preparation, detection and analysis, containment, eradication, recovery, and post-incident improvement. A copilot can assist with detection and analysis, but containment decisions may interrupt business operations and therefore require accountable human authorization.

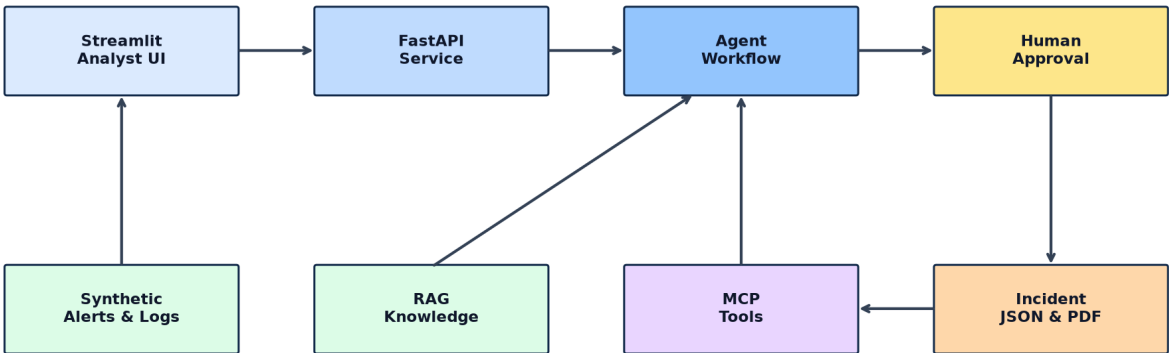
Retrieval-Augmented Generation supplies controlled context at inference time. It does not guarantee truth: relevance thresholds, metadata, provenance, citation checks, and unsupported-claim measurement are still required. Model Context Protocol standardizes how AI applications discover and invoke external tools and data sources. In this design, MCP is a security boundary: tools are narrow, validated, bounded, and separated by scope.

Agentic architecture divides responsibilities into triage, evidence correlation, threat context, retrieval, risk, response, and reporting. The separation is valuable only when state, handoffs, failures, and sources are observable. Repeating one source across agents must not inflate confidence.

4. System Architecture

The analyst interface calls a FastAPI service that orchestrates narrow agents. Evidence comes from synthetic alerts and related events. The RAG component reads controlled Markdown playbooks, while MCP servers expose bounded functions. Every proposed operational action remains a draft until human approval. The resulting JSON record is the source for the incident PDF.

Pydantic models form the data contract. This prevents loosely structured agent output from silently entering the report or approval workflow. The agent trace records actor, time, summary, and inputs for each material conclusion.



Trust rule: retrieved content and logs are data, never instructions. Operational actions remain drafts until analyst approval.

5. Dataset

The included dataset contains three deliberately small, synthetic alert scenarios: suspicious authentication, phishing, and encoded PowerShell execution. Related event fixtures emulate identity-provider, email-gateway, and endpoint telemetry. Documentation includes authentication, phishing, endpoint, and evidence/approval playbooks.

Preparation normalizes identifiers, ISO timestamps, entity fields, event counts, asset criticality, and descriptions. The small dataset is suitable for exercising architecture and test instrumentation, not training or estimating production accuracy. Reserved documentation IP ranges and the .example domain avoid accidental interaction with real infrastructure.

Field	Purpose	Example
alert_id / timestamp	Identity and ordering	ALT-001 / ISO-8601
source / category	Routing and provenance	Synthetic SIEM / authentication
user / device / IP	Entity correlation	a.patel / FIN-LT-042
event_count	Volume signal	14
asset_criticality	Business impact proxy	1-5
description	Human-readable observation	Failed logins followed by success

6. RAG Implementation

Markdown documents are parsed into chunks of at most 1,200 characters with 150-character overlap. Each chunk retains source ID, title, section, and path. The MVP vectorizes chunk text with word and bigram TF-IDF, ranks by cosine similarity, applies a minimum score, and returns the top three citations.

TF-IDF is an auditable retrieval baseline, not a semantic embedding model. The repository exposes one retriever interface so a sentence-transformer plus FAISS, Chroma, Qdrant, or pgvector backend can replace it. The replacement should be justified by Recall@k, MRR, citation precision, latency, and failure-case performance, rather than assumed to be better.

Retrieved text is treated as untrusted data. It may inform a response but cannot change system policy or invoke a tool. Empty retrieval produces an explicit knowledge gap instead of fabricated context.

7. MCP Implementation

MCP servers are separated by data domain and privilege. The logs server is read-only and bounded. The threat-intelligence server queries only an approved synthetic fixture and returns unknown when no source matches. The incidents server retrieves stored results and can create a draft ticket object; it cannot submit or change operational state.

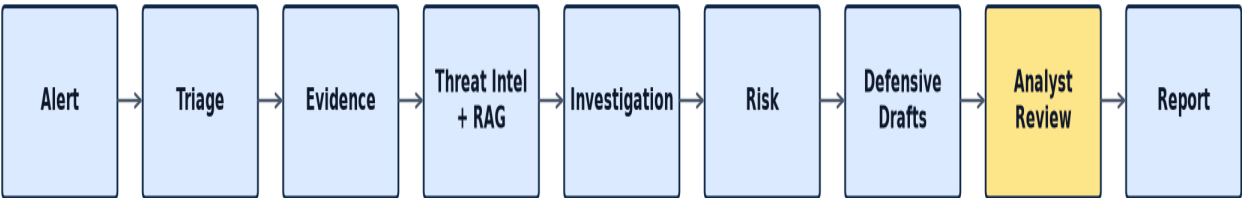
Production authorization should bind user identity, role, tenant, purpose, and incident scope to every request. Tool descriptions are not access controls. Server-side input validation, query templates, output limits, timeouts, rate limits, redaction, audit records, and secrets isolation are required.

Server	Tool	Scope	Side effect
soc-logs-readonly	search_activity	Exact alert ID; max 500	None
soc-threat-intel-approved	lookup_indicator	One approved fixture	None
soc-incidents-controlled	retrieve_incident	Stored incident read	None
soc-incidents-controlled	create_draft_ticket	Draft only	No submission

8. Multi-Agent Architecture

The orchestrator passes typed state through seven responsibilities. Each agent produces a bounded result, and the trace records its inputs and summary. No agent can execute containment. ATT&CK; mappings contain a technique ID, name, and evidence basis and are labelled provisional when the observation is incomplete.

The production evolution can use LangGraph for durable checkpoints, interrupts, retries, and resumable human review. The deterministic orchestrator remains a test oracle and fallback.



Agent	Output	Primary control
Triage	Type, severity, priority	Deterministic features
Investigation	Evidence, timeline, entities	Provenance and hypotheses
Threat intelligence	Approved matches	Unknown is not benign
RAG	Ranked chunks and citations	Threshold and source IDs
Risk	Score, level, confidence	Explicit bounded formula
Response	Defensive drafts	Approval required
Report	JSON/PDF record	No new facts

9. Implementation

The Python repository separates application contracts, agents, retrieval, MCP servers, dashboard, evaluation, reports, configuration, data, and tests. All core investigation logic runs locally without an LLM key. Optional hosted or local models should be adapters, not hidden global dependencies.

Errors are expected to fail closed: missing incidents return not-found responses; an intelligence miss returns no approved match; retrieval below threshold returns no context; and recommendations do not become actions. Persistent production storage should add transactions, row-level authorization, retention, and immutable audit events.

Layer	Implementation
Interface	Streamlit dashboard with alert selection, evidence tables, approval, PDF download
API	FastAPI endpoints for alerts, investigation, approval, and report download
Contracts	Pydantic models with bounded severity, confidence, and scores
Storage	Versioned JSON fixtures and incident records for MVP
Reporting	ReportLab-generated incident and technical PDFs
Testing	Determinism, provenance, approval gating, RAG retrieval, labelled cases

10. Example Incident Investigation

ALT-001 reports fourteen failed sign-ins followed by a successful login to a finance account from reserved documentation IP 203.0.113.77. The investigation correlates an MFA denial and the successful password sign-in. These are evidence. Account compromise remains a hypothesis until user, endpoint, and identity context confirm it.

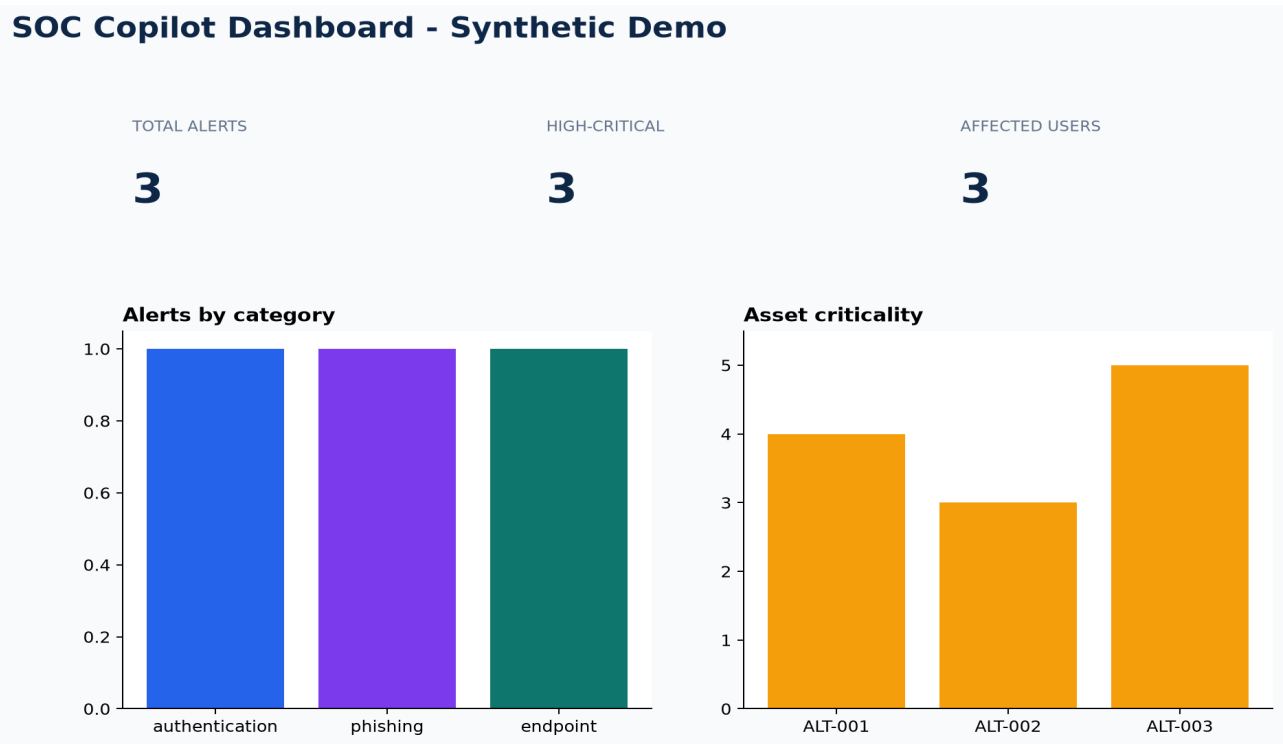
The controlled intelligence fixture marks the IP synthetic-malicious, and the authentication playbook is retrieved with citations. The rule baseline produces a critical risk decision and proposes log preservation, sign-in review, credential reset/session revocation, and possible host isolation. Each operational step remains approval-gated. A provisional T1078 Valid Accounts mapping records its basis rather than presenting the mapping as proof of attribution.

Stage	Result
Triage	Authentication; critical priority
Evidence	Alert + MFA denial + successful login
RAG	Authentication playbook and evidence policy
Risk	Critical; explicit score and confidence
Response	Approval-gated defensive actions
Report	JSON plus SOC_Incident_Report_INC-001.pdf

11. SOC Dashboard

The dashboard prioritizes analyst decisions: alert counts, entity coverage, category distribution, asset criticality, incident selection, risk and confidence, confirmed evidence, hypotheses, knowledge citations, defensive recommendations, approval controls, and PDF export. The image below is a generated preview from the repository's synthetic data; it is not presented as a production screenshot.

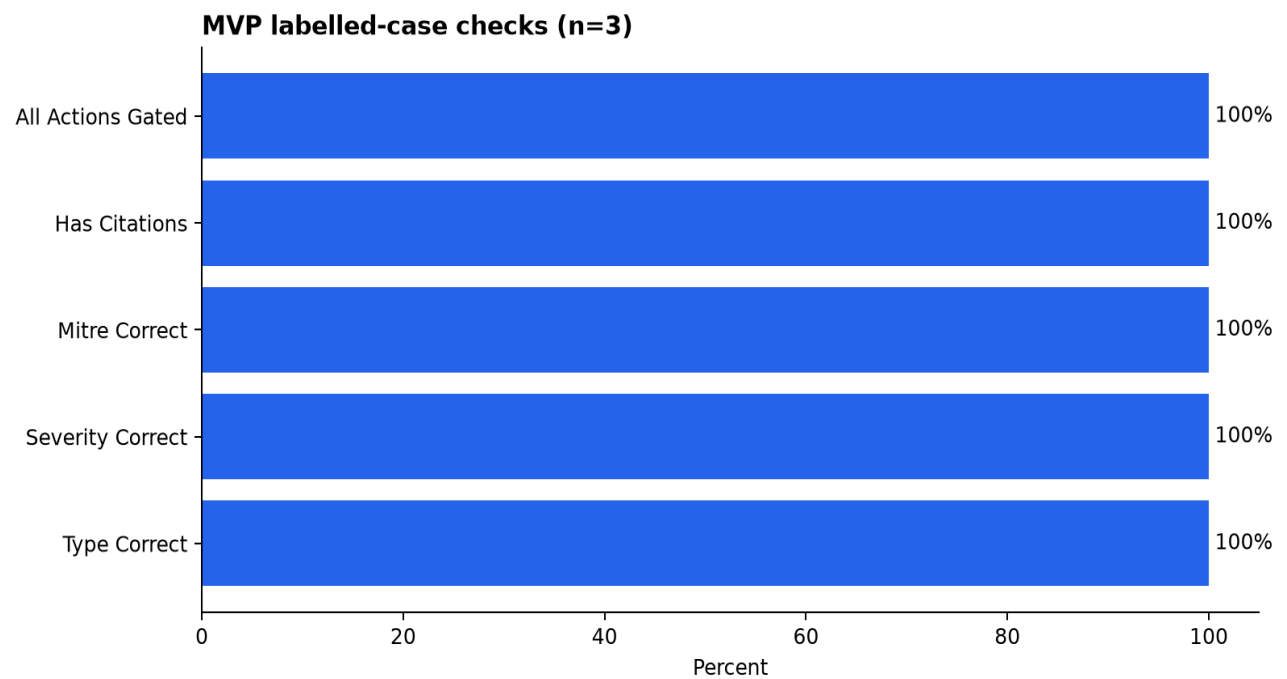
Later metrics should include incident volume over time, status, top affected systems and users, common ATT&CK; techniques, mean investigation time, false escalation, and agent confidence calibration. Dashboard filters must not conceal data quality or sampling limitations.



12. Evaluation and Results

Three manually labelled synthetic cases exercise classification, severity, ATT&CK; mapping, citation presence, and approval gating. All checks pass. This is a pipeline verification result, not a statistically meaningful performance estimate. A credible next evaluation needs at least 100 independently labelled cases, benign near-misses, ambiguous alerts, missing telemetry, contradictory sources, injection attempts, timeouts, and unavailable tools.

The full framework should calculate classification precision/recall/F1; retrieval Recall@k and MRR; citation entailment and precision; grounded-answer and unsupported-claim rates; false escalation; risk repeatability; tool selection precision; recovery success; latency; and cost. Human reviewers should score summary correctness, actionability, and evidence separation using a blinded rubric.



Metric	MVP result	Interpretation
Alert type accuracy	3/3	Fixture coverage only
Severity accuracy	3/3	Labels match explicit rubric
ATT&CK; mapping check	3/3	Technique expected in each fixture
Citation presence	3/3	At least one retrieved source
Approval gating	100%	Every recommendation gated

13. Safety and Security

The safety model assumes alerts, logs, emails, retrieved documents, and tool output can contain adversarial instructions. They never override the shared system contract. Every high-impact conclusion is traceable to evidence or an approved knowledge source, and unsupported statements belong in hypotheses or unknowns.

Human approval is necessary but insufficient. A production build also requires authenticated identity, role-based authorization, separation of duties, two-person approval for high-impact actions, immutable audit logs, replay protection, output encoding, secrets management, dependency scanning, rate limits, and incident-specific tool scopes.

Risk	Control
Prompt injection	Treat all external text as data; fixed policy; schema validation; no tool instructions from content
Tool abuse	Narrow servers, bounded parameters, server-side authorization, no shell tool
Hallucination	Citations, unknown states, unsupported-claim metric, deterministic fallback
Data leakage	Synthetic default, minimization, redaction, scoped storage and retention
Excessive agency	Draft-only recommendations and named analyst approval
Supply chain	Pinned ranges, lockfile/scan in CI, reviewed model and embedding artifacts

14. Limitations, Future Work, and Conclusion

Limitations include the tiny synthetic dataset, a lexical rather than semantic retriever, fixture-only intelligence, no real SIEM connection, JSON persistence, no authentication, and no latency or cost study. Deterministic rules can be brittle and the current confidence score is a rubric output, not calibrated probability. These restrictions must remain visible in the portfolio.

Future work should expand independent labels; compare embedding and lexical retrieval; add persistent LangGraph checkpoints; integrate a read-only lab SIEM and licensed intelligence; implement OIDC and role scopes; evaluate prompt injection and tool failure; add feedback with reviewer provenance; and deploy with observability, retention, and cost controls.

The project demonstrates a complete defensive investigation loop: ingestion, triage, evidence correlation, controlled retrieval, threat context, explainable risk, approval-gated recommendations, dashboarding, evaluation, and reporting. Its technical contribution is not autonomous response. It is an auditable architecture that makes an AI assistant easier to test, constrain, and challenge.

15. References

- [1] MITRE. ATT&CK;: Enterprise tactics, techniques, and resources. <https://attack.mitre.org/>
- [2] Model Context Protocol. Specification and architecture documentation. <https://modelcontextprotocol.io/specification/>
- [3] LangChain. LangGraph documentation: orchestration for long-running stateful agents. <https://docs.langchain.com/oss/python/langgraph/overview>
- [4] OWASP. LLM Prompt Injection Prevention Cheat Sheet. https://cheatsheetseries.owasp.org/cheatsheets/LLM_Prompt_Injection_Prevention_Cheat_Sheet.html
- [5] OWASP. AI Agent Security Cheat Sheet. https://cheatsheetseries.owasp.org/cheatsheets/AI_Agent_Security_Cheat_Sheet.html
- [6] NIST. Computer Security Incident Handling Guide, SP 800-61 Rev. 2. <https://csrc.nist.gov/publications/detail/sp/800-61/rev-2/final>
- [7] FastAPI documentation. <https://fastapi.tiangolo.com/>
- [8] Pydantic documentation. <https://docs.pydantic.dev/>
- [9] Streamlit documentation. <https://docs.streamlit.io/>
- [10] scikit-learn. Feature extraction and cosine similarity documentation. <https://scikit-learn.org/>

Appendix A - Schemas, prompts, and tests

The repository contains the complete shared system contract and seven agent prompts in docs/agent_prompts.md; JSON MCP schemas in docs/mcp_tool_schemas.json; three labelled test cases; deterministic unit tests; and machine-readable evaluation output.

Representative risk formula

$\text{risk} = \min(100, 0.55 \times \text{triage_score} + 7 \times \text{evidence_count} + 10 \times \text{approved_intelligence_hits} + 4 \times \text{asset_criticality})$

This is an explainable engineering baseline. Weights must be calibrated against independently labelled data before operational use.

Selected completion checks

- Every evidence item has provenance.
- Evidence and hypotheses are stored separately.
- Every defensive recommendation requires approval.
- A missing intelligence match is returned as unknown.
- RAG results include source ID, section, and similarity score.
- Incident JSON is the authoritative input to the incident PDF.
- Evaluation output carries an explicit small-sample warning.